

**TỔNG LIÊN ĐOÀN LAO ĐỘNG VIỆT NAM
TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG
KHOA CÔNG NGHỆ THÔNG TIN**



VÕ MẠNH CƯỜNG - 52200319

**DỊCH VỤ THƯ TÍN SỐ AN TOÀN
MẬT THƯ - SECRET LETTER**

**MẠNG MÁY TÍNH
VÀ TRUYỀN THÔNG DỮ LIỆU**

THÀNH PHỐ HỒ CHÍ MINH – 2025

**TỔNG LIÊN ĐOÀN LAO ĐỘNG VIỆT NAM
TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG
KHOA CÔNG NGHỆ THÔNG TIN**



VÕ MẠNH CƯỜNG - 52200319

**DỊCH VỤ THƯ TÍN SỐ AN TOÀN
MẬT THƯ - SECRET LETTER**

**MẠNG MÁY TÍNH
VÀ TRUYỀN THÔNG DỮ LIỆU**

Người hướng dẫn
TS. Trần Thanh Nam

THÀNH PHỐ HỒ CHÍ MINH – 2025

LỜI CẢM ƠN

Em xin chân thành gửi lời cảm ơn sâu sắc đến TS. Trần Thanh Nam đã tận tình giảng dạy, hỗ trợ và truyền đạt kiến thức trong quá trình thực hiện dự án.

Tuy nhiên em còn hạn chế nhiều về kiến thức nên không thể tránh khỏi những thiếu sót trong quá trình hoàn thành dự án này. Mong quý thầy/cô xem và góp ý để bài báo cáo của em được cải thiện hơn.

CÔNG TRÌNH ĐƯỢC HOÀN THÀNH TẠI TRƯỜNG ĐẠI HỌC TÔN ĐỨC THẮNG

Tôi xin cam đoan đây là sản phẩm đồ án của riêng tôi và được sự hướng dẫn của TS. Trần Thanh Nam. Các nội dung nghiên cứu, kết quả trong đề tài này là trung thực và chưa công bố dưới bất kỳ hình thức nào trước đây. Những số liệu trong các bảng biểu phục vụ cho việc phân tích, nhận xét, đánh giá được chính tôi thu thập từ các nguồn khác nhau có ghi rõ trong phần tài liệu tham khảo.

Ngoài ra, trong đồ án còn sử dụng một số nhận xét, đánh giá cũng như số liệu của các tác giả khác, cơ quan tổ chức khác đều có trích dẫn và chú thích nguồn gốc.

Nếu phát hiện có bất kỳ sự gian lận nào tôi xin hoàn toàn chịu trách nhiệm về nội dung đồ án của mình. Trường đại học Tôn Đức Thắng không liên quan đến những vi phạm tác quyền, bản quyền do tôi gây ra trong quá trình thực hiện (nếu có).

TP.Hồ Chí Minh, ngày 07 tháng 01 năm 2026

Tác giả

(ký và ghi rõ họ tên)

Võ Mạnh Cường

DỊCH VỤ THƯ TÍN SỐ AN TOÀN MẬT THƯ - SECRET LETTER TÓM TẮT

Trong bối cảnh bảo mật thông tin số ngày càng được đề cao, việc chia sẻ các dữ liệu nhạy cảm (như mật khẩu, token, API keys) qua các kênh truyền thông thông thường tiềm ẩn nhiều rủi ro rò rỉ. Dự án Secret Letter ra đời nhằm giải quyết vấn đề này bằng cách xây dựng một ứng dụng web cho phép chia sẻ bí mật một lần, kết hợp cơ chế mã hóa phía máy khách (Client-Side Encryption) và kiến trúc Zero-Knowledge.

Hệ thống được thiết kế sử dụng thuật toán AES-256-GCM qua Web Crypto API, đảm bảo dữ liệu luôn được mã hóa tại trình duyệt người dùng trước khi gửi đến máy chủ. Điểm nổi bật là khóa giải mã được nhúng vào URL fragment, giúp ngăn chặn triệt để việc máy chủ tiếp cận được nội dung giải mã. Phía Backend sử dụng Golang kết hợp với Redis để xử lý logic lưu trữ có thời hạn (TTL) và đảm bảo tính nguyên tử (atomic) để bí mật chỉ có thể được đọc một lần duy nhất.

Kết quả triển khai hệ thống cho thấy Secret Letter không chỉ đáp ứng tốt các yêu cầu về an toàn thông tin mà còn duy trì hiệu năng cao, khả năng chịu tải tốt và chống lại các bot cào dữ liệu qua cơ chế Reveal Gate. Hệ thống sẵn sàng làm nền tảng cho các nghiệp vụ trao đổi thông tin nhạy cảm của cá nhân và doanh nghiệp.

SECURE DIGITAL MAILING SERVICE MAT THU - SECRET LETTER ABSTRACT

In the context of increasing digital information security, sharing sensitive data (such as passwords, tokens, API keys) through conventional communication channels poses significant leakage risks. The Secret Letter project addresses this issue by building a web application for one-time secret sharing, combining Client-Side Encryption and a Zero-Knowledge architecture.

The system is designed using the AES-256-GCM algorithm via the Web Crypto API, ensuring that data is always encrypted in the user's browser before being sent to the server. A key feature is that the decryption key is embedded in the URL fragment, completely preventing the server from accessing the plaintext content. The Backend uses Golang combined with Redis to handle time-to-live (TTL) storage logic and ensure atomic operations so that a secret can only be read exactly once.

Deployment results show that Secret Letter not only meets strict information security requirements but also maintains high performance, handles concurrent loads effectively, and protects against web crawlers through a Reveal Gate mechanism. The system is well-prepared to serve as a foundation for sensitive information exchange.

Mục lục

DANH MỤC HÌNH VẼ	vii
DANH MỤC BẢNG BIỂU	viii
DANH MỤC CÁC TỪ VIẾT TẮT	ix
CHƯƠNG 1 GIỚI THIỆU CHUNG VỀ DỰ ÁN	1
1.1 Lý do chọn đề tài	1
1.2 Mục tiêu dự án	2
1.3 Phạm vi nghiên cứu	3
CHƯƠNG 2 CƠ SỞ LÝ THUYẾT VÀ CÔNG NGHỆ	4
2.1 Mật mã học ứng dụng	4
2.1.1 Thuật toán AES và chế độ GCM	4
2.1.2 Lý do chọn AES-256-GCM	5
2.2 Kiến trúc Client-Side Encryption	7
2.2.1 Khái niệm và Nguyên lý hoạt động	7
2.2.2 Sơ đồ kiến trúc toàn trình (End-to-End)	7
2.2.3 Cơ chế bảo vệ bằng URL Fragment	8
2.3 Công nghệ Backend	9
2.4 Công nghệ Frontend	9
CHƯƠNG 3 PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG	10
3.1 Phân tích yêu cầu	10
3.2 Kiến trúc tổng thể	10
3.3 Thiết kế luồng dữ liệu	10

3.4 Thiết kế API	10
CHƯƠNG 4 TRIỂN KHAI CHI TIẾT	11
4.1 Cấu trúc mã nguồn	11
4.2 Triển khai Frontend	11
4.3 Triển khai Backend	11
4.4 Giải quyết bài toán kỹ thuật	11
CHƯƠNG 5 ĐÁNH GIÁ BẢO MẬT, KIỂM THỬ VÀ VẬN HÀNH	12
5.1 Mô hình đe dọa và biện pháp phòng chống	12
5.2 Chiến lược kiểm thử	12
5.3 Đánh giá hiệu năng	12
5.4 Quy trình CI/CD và Triển khai	12
KẾT LUẬN	13
TÀI LIỆU THAM KHẢO	14

Danh sách hình vẽ

2.1	Mô hình tổng quan đầu vào và đầu ra của thuật toán AES-GCM	5
2.2	Kiến trúc Client-Side Encryption và cơ chế phân phối khóa qua URL Fragment	7

Danh sách bảng

Danh mục các từ viết tắt

Viết tắt	Ý nghĩa
AAD	Additional Authenticated Data – Dữ liệu xác thực bổ sung (trong cơ chế AEAD/AES-GCM)
ACK	Acknowledgement – Thông điệp xác nhận đã nhận/xử lý
AEAD	Authenticated Encryption with Associated Data – Mã hóa xác thực kèm dữ liệu liên kết
AES	Advanced Encryption Standard – Chuẩn mã hóa đối xứng AES
CORS	Cross-Origin Resource Sharing – Cơ chế chia sẻ tài nguyên khác nguồn (trình duyệt)
CSRF	Cross-Site Request Forgery – Tấn công giả mạo yêu cầu liên trang
CRUD	Create, Read, Update, Delete – 4 thao tác dữ liệu cơ bản
DB	Database – Cơ sở dữ liệu
E2EE	End-to-End Encryption – Mã hóa đầu-cuối
ESM	ECMAScript Module – Cơ chế module chuẩn của JavaScript
FIDO2	Fast IDentity Online 2 – Chuẩn xác thực không mật khẩu của FIDO Alliance
FIPS	Federal Information Processing Standards – Bộ tiêu chuẩn xử lý thông tin liên bang (Mỹ)

(Tiếp theo trang sau)

Viết tắt	Ý nghĩa
GCM	Galois/Counter Mode – Chế độ vận hành (mode) của AES cung cấp mã hóa xác thực
GDPR	General Data Protection Regulation – Quy định bảo vệ dữ liệu chung (EU)
GMAC	Galois Message Authentication Code – Mã xác thực dựa trên GCM (dạng MAC)
HMAC	Hash-based Message Authentication Code – Mã xác thực thông điệp dựa trên hàm băm
HMR	Hot Module Replacement – Cơ chế nạp nóng module trong môi trường phát triển
HS256	HMAC-SHA-256 – Thuật toán ký JWT dùng HMAC với SHA-256
IV	Initialization Vector – Vector khởi tạo/nonce dùng cho mã hóa đối xứng (ngữ cảnh AES-GCM)
JSON	JavaScript Object Notation – Định dạng dữ liệu JSON
JWT	JSON Web Token – Token xác thực/phiên làm việc
MGF1	Mask Generation Function 1 – Hàm sinh mặt nạ (dùng trong OAEP/PSS)
NIST	National Institute of Standards and Technology – Viện tiêu chuẩn và công nghệ Hoa Kỳ
OAEP	Optimal Asymmetric Encryption Padding – Lược đồ đệm cho RSA dùng trong key wrapping
ODM	Object–Document Mapper – Ánh xạ Object–Document (MongoDB)
OTP	One-Time Password – Mật khẩu dùng một lần
PBKDF2	Password-Based Key Derivation Function 2 – Hàm dẫn xuất khóa từ mật khẩu/PIN

(Tiếp theo trang sau)

Viết tắt	Ý nghĩa
PIN	Personal Identification Number – Mã PIN người dùng
PSS	Probabilistic Signature Scheme – Lược đồ chữ ký xác suất của RSA (RSA-PSS)
REST	Representational State Transfer – Phong cách thiết kế API (REST API)
RSA	Rivest–Shamir–Adleman – Thuật toán mật mã bất đối xứng RSA
RSAES	RSA Encryption Scheme – Hệ lược đồ mã hóa RSA (ngữ cảnh RSAES-OAEP)
RSASSA	RSA Signature Scheme with Appendix – Hệ lược đồ chữ ký RSA (ngữ cảnh RSASSA-PSS)
SHA	Secure Hash Algorithm – Họ hàm băm SHA (ngữ cảnh SHA-256)
SPA	Single Page Application – Ứng dụng web một trang
TLS	Transport Layer Security – Bảo mật tầng vận chuyển
TOFU	Trust On First Use – Tin cậy lần đầu; thay đổi khóa cần xác minh lại
UI	User Interface – Giao diện người dùng
UI/UX	User Interface / User Experience – Giao diện người dùng / Trải nghiệm người dùng
URL	Uniform Resource Locator – Địa chỉ tài nguyên (đường dẫn)
USENIX	USENIX Association – Tổ chức/hội nghị nghiên cứu hệ thống (ngữ cảnh trích dẫn)
W3C	World Wide Web Consortium – Tổ chức tiêu chuẩn web (W3C)
UX	User Experience – Trải nghiệm người dùng

CHƯƠNG 1 GIỚI THIỆU CHUNG VỀ DỰ ÁN

1.1 Lý do chọn đề tài

Trong kỷ nguyên số hóa hiện nay, việc trao đổi thông tin nhạy cảm như mật khẩu, khóa API, mã thông báo truy cập (access token) hay dữ liệu cá nhân diễn ra thường xuyên trong môi trường doanh nghiệp cũng như giữa các cá nhân. Tuy nhiên, việc chia sẻ qua các kênh giao tiếp phổ biến như email, các ứng dụng nhắn tin (Zalo, Messenger, Slack, v.v.) vẫn tiềm ẩn nhiều rủi ro về an toàn thông tin. Các dữ liệu này thường được lưu trữ trong thời gian dài trên máy chủ của nhà cung cấp dịch vụ hoặc trong lịch sử trò chuyện. Điều này tạo ra rủi ro lớn về rò rỉ thông tin nếu máy chủ bị tấn công hoặc tài khoản người dùng bị xâm nhập.

Bên cạnh đó, phần lớn các hệ thống lưu trữ hiện nay thực hiện việc mã hóa ở phía máy chủ (Server-side Encryption), đòi hỏi người dùng phải phụ thuộc nhiều vào nhà cung cấp. Nếu nhà cung cấp dịch vụ bị tổn hại, các dữ liệu bí mật cũng có nguy cơ bị lộ.

Để giải quyết bài toán trên, tôi đã quyết định chọn đề tài **”Dịch vụ thư tín số an toàn Mật thư - Secret Letter”**. Dự án ứng dụng kiến trúc *Zero-Knowledge* và cơ chế mã hóa phía máy khách (*Client-side Encryption*). Nội dung bí mật sẽ được mã hóa trực tiếp trên trình duyệt người dùng bằng các thuật toán mã hóa tiêu chuẩn (như AES-256-GCM) trước khi gửi đi. Điểm đặc biệt là khóa giải mã được đính kèm trong phần phân mảnh của URL (URL fragment), giúp hạn chế máy chủ tiếp cận nội dung gốc. Hơn nữa, thông điệp được thiết lập cơ chế chỉ đọc một lần (one-time read) và tự hủy sau khi đọc hoặc hết hạn, giúp giảm thiểu tối đa dấu vết dữ liệu trên hệ thống.

Đề tài này mang ý nghĩa thực tiễn trong việc nâng cao bảo mật thông tin, đồng thời là cơ hội để tôi nghiên cứu sâu hơn về kiến trúc phân tán, công nghệ mã hóa hiện đại và các giải pháp Backend hiệu năng cao bằng Golang.

1.2 Mục tiêu dự án

Dự án ”Dịch vụ thư tín số an toàn Mật thư - Secret Letter” được thực hiện nhằm hướng đến các mục tiêu chính yếu sau:

Mục tiêu tổng quát: Xây dựng một ứng dụng web hoạt động độc lập, cho phép người dùng chia sẻ các đoạn thông tin nhạy cảm (như mật khẩu, token, khóa API) một cách an toàn và dễ sử dụng. Hệ thống hướng đến nguyên tắc cốt lõi: bí mật chỉ có thể được xem một lần duy nhất và hạn chế tối đa khả năng phía máy chủ đọc được nội dung gốc của thông điệp.

Mục tiêu cụ thể:

- *Về mặt lý thuyết:* Tìm hiểu và ứng dụng các chuẩn mã hóa tiên tiến hiện nay (đặc biệt là AES-256-GCM), nghiên cứu nguyên lý hoạt động của kiến trúc Zero-Knowledge và cơ chế mã hóa phía máy khách (Client-side Encryption) thông qua Web Crypto API.
- *Về mặt phát triển ứng dụng:* Thiết kế và triển khai thành công hệ thống Backend hiệu năng cao sử dụng ngôn ngữ Golang kết hợp với Redis để xử lý lưu trữ tạm thời (in-memory) và quản lý vòng đời (Time-to-Live) của các thông điệp một cách tối ưu. Ở phía Frontend, xây dựng giao diện trực quan, dễ tương tác giúp quá trình mã hóa và chia sẻ diễn ra liền mạch trên trình duyệt.
- *Về mặt bảo mật hệ thống:* Triển khai các cơ chế bảo vệ nâng cao như Reveal Gate để hỗ trợ ngăn chặn sự thu thập tự động từ các bot (web crawlers) và phần mềm quét liên kết trên các nền tảng nhắn tin. Đồng thời, áp dụng tính nguyên tử (atomic) trong quá trình truy xuất dữ liệu

để đảm bảo thông điệp bị tiêu hủy ngay sau lượt đọc đầu tiên.

1.3 Phạm vi nghiên cứu

Để đảm bảo tính khả thi và tập trung nâng cao tính bảo mật trong giao tiếp kỹ thuật số ngắn hạn, dự án được giới hạn trong các phạm vi sau:

Phạm vi chức năng và dữ liệu:

- Hệ thống trong giai đoạn này chủ yếu hỗ trợ việc mã hóa và chia sẻ nội dung dưới dạng văn bản (text), phục vụ cho các trường hợp trao đổi thông tin ngắn như chuỗi mật khẩu, đường dẫn bí mật, cấu hình hệ thống hay mã thông báo truy cập.
- Việc hỗ trợ mã hóa và truyền tải các tệp tin đa phương tiện lớn (hình ảnh, video, tài liệu dung lượng cao) sẽ nằm ngoài phạm vi của phiên bản hiện tại để tập trung tối ưu hóa tốc độ và độ tin cậy của dịch vụ cốt lõi.

Phạm vi công nghệ:

- *Trình duyệt và Client-side*: Sử dụng các tiêu chuẩn web hiện đại, trong đó yêu cầu trình duyệt của người dùng phải hỗ trợ Web Crypto API để có thể thực thi các tác vụ mã hóa, giải mã AES-256-GCM.
- *Máy chủ Backend*: Hệ thống được xây dựng để cung cấp các API RESTful xử lý bằng Golang và lưu trữ trạng thái tại Redis. Các cơ sở dữ liệu quan hệ (SQL) hay các hình thức lưu trữ ổ cứng vĩnh viễn (persistent storage) sẽ không được sử dụng nhằm phù hợp với tính chất tự hủy và giảm thiểu lưu vết của hệ thống.

Đối tượng và môi trường áp dụng: Sản phẩm hướng tới các lập trình viên, chuyên gia công nghệ thông tin hoặc bất kỳ người dùng cá nhân hay doanh nghiệp nào có nhu cầu chia sẻ dữ liệu nhạy cảm thông qua các kênh trung gian kém an toàn (Zalo, Messenger, Email, v.v.) mà vẫn muốn cải thiện mức độ an toàn thông tin.

CHƯƠNG 2 CƠ SỞ LÝ THUYẾT VÀ CÔNG NGHỆ

2.1 Mật mã học ứng dụng

Trong việc bảo vệ dữ liệu nhạy cảm trên môi trường trực tuyến, mã hóa là cơ chế phòng thủ cốt lõi. Dự án *Secret Letter* áp dụng thuật toán mã hóa đối xứng AES (Advanced Encryption Standard) với chế độ hoạt động GCM (Galois/Counter Mode), kết hợp độ dài khóa 256-bit (AES-256-GCM). Đây là một trong những chuẩn mã hóa được tin dùng rộng rãi và được chuẩn hóa toàn cầu, đáp ứng các yêu cầu về cả hiệu năng và độ an toàn (Dworkin, 2007).

2.1.1 Thuật toán AES và chế độ GCM

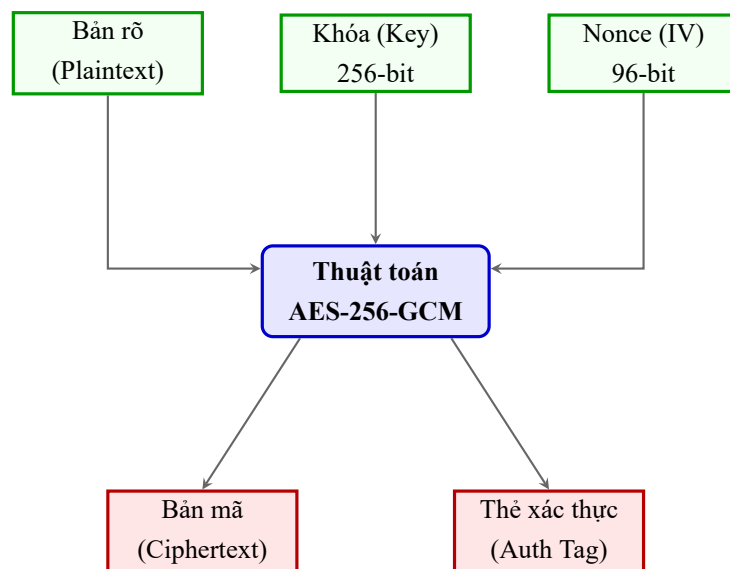
AES là thuật toán mã hóa khối (block cipher) hoạt động với kích thước khối cố định là 128-bit và độ dài khóa có thể là 128, 192 hoặc 256-bit. Trong dự án này, độ dài khóa 256-bit được sử dụng nhằm cung cấp mức độ bảo vệ vững chắc trước các phương pháp tấn công vét cạn (brute-force).

Tuy nhiên, bản thân thuật toán mã hóa khối chỉ phát huy hiệu quả khi được kết hợp với một chế độ hoạt động (mode of operation) phù hợp. GCM là một chế độ hoạt động cung cấp cơ chế **Mã hóa xác thực kèm dữ liệu liên kết (Authenticated Encryption with Associated Data - AEAD)**. GCM kết hợp hai chức năng:

- **Bảo mật (Confidentiality):** GCM sử dụng biến thể của chế độ CTR (Counter) để mã hóa luồng dữ liệu, cho phép quá trình mã hóa và giải mã được thực hiện song song, tối ưu hóa đáng kể tốc độ xử lý phần mềm.
- **Xác thực (Authenticity):** GCM sử dụng phép nhân trên trường Galois hữu hạn (GHASH) để tạo ra một thẻ xác thực (Authentication Tag). Thẻ

này đóng vai trò như một chữ ký số đi kèm bản mã (ciphertext), giúp phát hiện bất kỳ sự can thiệp, biến đổi nào đối với bản mã trong quá trình truyền tải (Dworkin, 2007).

Quá trình mã hóa AES-GCM yêu cầu ba yếu tố đầu vào chính: Khóa bí mật (Secret Key), Bản rõ (Plaintext) và một giá trị ngẫu nhiên không lặp lại gọi là Vector khởi tạo (Initialization Vector - IV hoặc Nonce). Trong dự án *Secret Letter*, IV được thiết lập với độ dài tiêu chuẩn là 12 byte (96-bit) và được tạo ngẫu nhiên cho mỗi phiên mã hóa. Việc sử dụng IV đảm bảo rằng hai thông điệp giống hệt nhau khi được mã hóa bằng cùng một khóa cũng sẽ tạo ra hai bản mã hoàn toàn khác biệt. Ở đầu ra, thuật toán trả về bản mã đính kèm thẻ xác thực.



Hình 2.1: Mô hình tổng quan đầu vào và đầu ra của thuật toán AES-GCM

2.1.2 Lý do chọn AES-256-GCM

Việc lựa chọn AES-256-GCM làm thuật toán mã hóa cốt lõi dựa trên các cơ sở kỹ thuật sau:

1. **Khả năng chống giả mạo dữ liệu (Tamper Resistance):** Khác với các chế độ cũ như CBC hay ECB, GCM tạo ra Authentication Tag. Khi giải mã, nếu một bit bất kỳ của bản mã hoặc IV bị kẻ tấn công

thay đổi trên đường truyền, bước xác thực sẽ thất bại và hàm giải mã sẽ từ chối trả về kết quả. Điều này giúp ngăn chặn các cuộc tấn công thay đổi bản mã (ciphertext malleability attack).

2. **Hỗ trợ phần cứng và hiệu năng xử lý:** Hầu hết các vi xử lý hiện đại (CPU) ở cả máy tính lẫn điện thoại đều tích hợp tập lệnh tăng tốc phần cứng cho AES và phép toán Galois. Nhờ đó, AES-GCM đạt được thông lượng xử lý cao, độ trễ thấp, đặc biệt phù hợp cho các ứng dụng web mã hóa trực tiếp trên thiết bị của người dùng (Client-side).
3. **Tính chuẩn hóa cao trên Web:** AES-GCM là chuẩn mã hóa ưu tiên được hỗ trợ đầy đủ bởi *Web Cryptography API* (World Wide Web Consortium (W3C) (2017)). Việc API này được tích hợp sẵn (native) trên mọi trình duyệt hiện đại giúp các tác vụ tính toán mật mã diễn ra an toàn ngay tại máy khách mà không cần nhập các thư viện bên thứ ba, làm giảm bớt rủi ro từ các lỗ hổng mã nguồn mở.
4. **An toàn trong Kỷ nguyên Lượng tử (Post-Quantum Security):** Theo báo cáo chuyên sâu của NIST về Mật mã Hậu lượng tử (Chen et al., 2016), sự ra đời của máy tính lượng tử cùng thuật toán Grover mang lại khả năng tăng tốc độ tìm kiếm bình phương (quadratic speedup) khi tấn công vét cạn các hệ mật đối xứng. Theo đó, thuật toán Grover sẽ làm giảm độ an toàn hiệu dụng của AES-256 đi một nửa, tức là từ 256-bit xuống còn tương đương với độ an toàn 128-bit. Tuy nhiên, mức độ bảo mật 128-bit lượng tử vẫn vượt quá khả năng tính toán thực tế của bất kỳ hệ thống nào trong tương lai. Nhờ vậy, việc triển khai khóa AES-256 giúp *Secret Letter* tiếp tục duy trì độ an toàn lâu dài ngay cả khi máy tính lượng tử trở nên phổ biến.

Sự kết hợp giữa AES-256 (bảo vệ bằng khóa dài) và GCM (xác thực tính toàn vẹn) giúp nền tảng đạt được sự cân bằng hợp lý giữa khả năng bảo mật nghiêm ngặt và hiệu năng vận hành thực tế mà không cần thêm

sơ đồ hạ tầng phức tạp.

2.2 Kiến trúc Client-Side Encryption

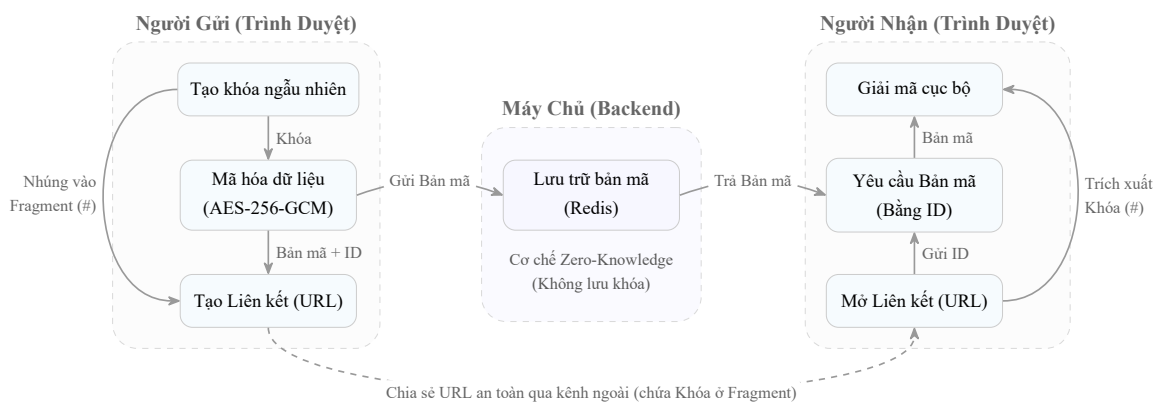
2.2.1 Khái niệm và Nguyên lý hoạt động

Mã hóa phía máy khách (Client-Side Encryption - CSE) là một mô hình bảo mật mà trong đó, quá trình mã hóa dữ liệu được thực hiện hoàn toàn trên thiết bị của người dùng (như trình duyệt web, điện thoại di động) trước khi bất kỳ dữ liệu nào được truyền tải qua mạng lưới internet hoặc lưu trữ trên máy chủ của bên thứ ba.

Trái ngược với mã hóa phía máy chủ (Server-Side Encryption) – nơi máy chủ nắm giữ cả bản rõ và khóa giải mã – kiến trúc CSE đảm bảo rằng máy chủ trung gian đóng vai trò như một hệ thống ”mù” (Zero-Knowledge). Máy chủ chỉ lưu trữ các cụm dữ liệu đã được mã hóa ngẫu nhiên và hoàn toàn không có khả năng đọc, phân tích hay khôi phục lại nội dung gốc do không sở hữu khóa bí mật.

2.2.2 Sơ đồ kiến trúc toàn trình (End-to-End)

Để hiện thực hóa mô hình Zero-Knowledge trong dự án *Secret Letter*, kiến trúc truyền tải dữ liệu và khóa giải mã được thiết kế như sơ đồ Hình 2.2 dưới đây:



Hình 2.2: Kiến trúc Client-Side Encryption và cơ chế phân phối khóa qua URL Fragment

2.2.3 Cơ chế bảo vệ bằng URL Fragment

Một trong những thách thức lớn nhất của Client-Side Encryption là làm thế nào để truyền tải khóa giải mã từ người gửi đến người nhận một cách an toàn mà không bị máy chủ trung gian đánh chặn. *Secret Letter* giải quyết triệt để vấn đề này bằng cách tận dụng thuộc tính **URL Fragment** (phần chuỗi ký tự đứng sau dấu thăng #).

Theo đặc tả giao thức HTTP do W3C và IETF quy định, các trình duyệt web khi thực hiện các truy vấn GET đến một máy chủ sẽ **tuyệt đối không bao giờ gửi phần Fragment** trong HTTP Request. Đoạn văn bản sau dấu # chỉ tồn tại ở bộ nhớ cục bộ (local memory) của trình duyệt để xử lý logic nội bộ.

Trong dự án:

1. **Phía gửi:** Khóa AES-256-GCM ngẫu nhiên được mã hóa dạng Base64Url và đính kèm vào đường dẫn (ví dụ: `https://secret.quorix.io.vn/secret/1`). Phần bản mã được gửi lên máy chủ lưu trữ với định danh là 12345.
2. **Phía nhận:** Khi người dùng truy cập vào liên kết, trình duyệt gửi yêu cầu lấy bản mã dựa vào ID 12345. Sau khi nhận được bản mã từ máy chủ, mã JavaScript trên trình duyệt của người nhận sẽ trích xuất khóa `KhóaB1M4t` từ thanh địa chỉ để tiến hành giải mã cục bộ.

Cơ chế này mang lại độ bảo mật vượt trội: ngay cả khi máy chủ Backend bị tin tặc chiếm quyền điều khiển hoàn toàn và thu thập toàn bộ cơ sở dữ liệu, chúng cũng chỉ có trong tay những chuỗi ký tự vô nghĩa vì **khóa giải mã chưa bao giờ rời khỏi thiết bị của người dùng để đi lên mạng Internet**. Điều này thiết lập nên kiến trúc Zero-Knowledge đúng nghĩa.

2.3 Công nghệ Backend

2.4 Công nghệ Frontend

CHƯƠNG 3 PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG

3.1 Phân tích yêu cầu

3.2 Kiến trúc tổng thể

3.3 Thiết kế luồng dữ liệu

3.4 Thiết kế API

CHƯƠNG 4 TRIỂN KHAI CHI TIẾT

4.1 Cấu trúc mã nguồn

4.2 Triển khai Frontend

4.3 Triển khai Backend

4.4 Giải quyết bài toán kỹ thuật

CHƯƠNG 5 ĐÁNH GIÁ BẢO MẬT, KIỂM THỬ VÀ VẬN HÀNH

5.1 Mô hình đe dọa và biện pháp phòng chống

5.2 Chiến lược kiểm thử

5.3 Đánh giá hiệu năng

5.4 Quy trình CI/CD và Triển khai

KẾT LUẬN

Dự án Secret Letter đã đạt được mục tiêu xây dựng một ứng dụng chia sẻ bí mật an toàn với kiến trúc Zero-Knowledge và mã hóa đầu-cuối tại trình duyệt (Client-side Encryption). Hệ thống đáp ứng tốt các yêu cầu khắt khe về bảo mật, hiệu năng, và trải nghiệm người dùng.

Trong tương lai, dự án có thể mở rộng thêm các tính năng như gửi thông báo qua email, cấp quyền xem linh hoạt hơn, và triển khai các mô hình phân tích hành vi người dùng một cách ẩn danh.

TÀI LIỆU THAM KHẢO

- Chen, L., Jordan, S., Liu, Y.-K., Moody, D., Peralta, R., Perlner, R., & Smith-Tone, D. (2016). Report on Post-Quantum Cryptography [NIST Internal Report (NISTIR) 8105].
- Dworkin, M. (2007). Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC [NIST Special Publication 800-38D].
- World Wide Web Consortium (W3C). (2017). Web Cryptography API [W3C Recommendation].